

Livrable 2 — Stack OSINT Log as Code

Sujet 1 : génération automatisée de politiques de logs de sécurité. Objectif : présenter les matières premières OSINT, les outils de collecte et les angles morts avant de construire le moteur de décision.

INTENTION DE MISSION

Nous ne cherchons pas seulement à générer un fichier YAML. Nous voulons transformer la CTI en décisions de journalisation : **quoi collecter, pourquoi, sur quel actif, et quel angle mort on accepte si on ne le collecte pas.**

QUESTION CENTRALE

Quels logs méritent réellement d'être collectés pour détecter les menaces prioritaires sans exploser le bruit, le coût et la charge analyste ?

A. Cadre OSINT

MÉTHODOLOGIE + OUTILS

Cartographie des sources

- MITRE ATT&CK — TTP, tactiques, plateformes, sources de données.
- CVE / NVD / CVSS — vulnérabilités, sévérité, exploitabilité.
- Mappings TTP/CVE/logs — lien menace → signal détectable.
- Logs de référence — Sysmon, Suricata, Apache, événements Windows, Linux syslog, trafic réseau.

Outils mobilisés

Python Parsing, scoring et génération de politiques.
pandas / csv / json Normalisation des formats hétérogènes.
STIX / attackcti Extraction future propre et à jour d'ATT&CK.
Jinja2 / YAML Production de politiques lisibles et versionnables.
Sigma / Splunk Validation du lien source de logs → logique de détection.

B. Inventaire des données

CATALOGUE + PROVENANCE + SIGNAL UTILE

DONNÉES SÉCURISÉES	PROVENANCE / FRAÎCHEUR	CONTENU	SIGNAL UTILE
Extrait_cve_data.JSON + cve_data_with_cvss_and_mitre.csv	Extrait local de données type CVE/NVD ; 5 CVE , échantillon statique.	Identifiant CVE, description, score/vecteur CVSS, logiciels affectés, exploitabilité, techniques ATT&CK associées.	Fournit le signal de sévérité et de priorité des vulnérabilités.
Extrait_mitre_attck.JSON	Extrait ATT&CK local ; source cible = MITRE Enterprise ATT&CK STIX. Échantillon statique et partiellement mal formé.	Noms de TTP, tactiques, plateformes, sources de données, composants de détection, procédures et exemples de requêtes.	Relie les menaces à des composants de détection observables.
mapping_ttps_cve_logs.csv	Mapping fourni dans le challenge ; 5 lignes mappées , immédiatement exploitables pour le MVP.	TTP, CVE, score, type/source de log, champs, exemple de log, requête Splunk, règle Sigma.	Signal clé : pont direct entre CTI et politique de journalisation.
Exemples de logs : Windows, Linux, Apache, Sysmon, Suricata, réseau XLSX	Logs synthétiques / démonstratifs fournis ; formats mixtes, suffisants pour une preuve de concept.	Exécution de processus, lignes de commande, payloads web, activité syslog, événements réseau et alertes.	Montre où les indicateurs apparaissent concrètement dans la télémétrie brute.
Dictionnaires de données	Dictionnaires CSV fournis pour les champs CVE/NVD et Enterprise ATT&CK.	Noms de champs, types, exemples, caractère obligatoire et descriptions.	Soutient une conception de schéma propre et une traçabilité explicable des données.

C. Angles morts et risques renseignement

DONNÉE MANQUANTE + CONTOURNEMENT

Donnée manquante

La donnée qui rendrait le projet vraiment décisif serait un inventaire d'actifs réaliste, proche Marine, avec la politique de logs actuelle, la volumétrie, le bruit et les contraintes de rétention par type d'actif.

Risque

Les données actuelles sont limitées et en partie synthétiques. Certains fichiers sont mal formés ou hétérogènes ; des promesses de performance trop fortes seraient donc fragiles.

Contournement

Utiliser des métriques proxy : CVSS + CISA KEV pour la priorité menace, ATT&CK Data Components pour la couverture, et un score simple coût/bruit par source de logs.

Angle stratégique : le projet n'est pas une "IA qui génère une politique de logs". C'est une couche de décision qui classe les logs qui valent réellement la peine d'être collectés selon la menace, l'actif et les contraintes opérationnelles.

Prochaine étape de construction : créer un MVP qui classe les recommandations de logs en **indispensable / recommandé / optionnel**, génère du YAML/JSON et explique chaque recommandation avec la TTP couverte, les champs requis, le coût/bruit estimé et l'angle mort restant.